LENGUAJE DE PROGRAMACIÓN 2

SPA segura, aviso de sesión y Mi cuenta

Actividad autónoma - Sesión 11 | PharmaSoft

Estudiante
James Christopher Tequen Oncoy

Docente
Benjamin David Reyna Barreto

Fecha de ejecución
25/10/2026 - America/Lima

Resultado final: 24 casos aprobados: 16 base, cuatro propios de grupos distintos y B-01 a B-04. Se detectaron y corrigieron tres hallazgos: L-03, I-02 y M-03.

Informe C1-C3: páginas 2 a 4. Las evidencias siguientes pertenecen únicamente a esta actividad; muestran la URL y ocultan los tokens completos.

Repositorio: PharmaFrontEnd · rama de la actividad autónoma
PR hacia develop: https://github.com/LeonardoTA/PharmaFrontEnd/pull/4

Los commits de esta actividad conservan su fecha real del 25/10/2026. Queda pendiente cumplir los commits propios en días distintos.

C1. Resumen de resultados

Se ejecutaron los 16 casos base, los propios L-05, S-05, G-03 y M-03 y los cuatro casos de aviso. La ejecución final tiene **24 casos que pasan y cero que fallan**. L-03, I-02 y M-03 fallaron inicialmente y se repitieron después de corregirse.

Grupo	Ejecutados	Pasan	Fallan
Login	5	5	0
Sesión	5	5	0
Interceptor	3	3	0
Guards	3	3	0
Menú y acciones	3	3	0
401 / 403	1	1	0
Aviso de expiración	4	4	0
Total	24	24	0

Entorno y trazabilidad

Angular 22 en localhost:4200, PharmaBackend en localhost:8081 y Oracle local en Docker. Las credenciales son las cinco cuentas de clase. I-02 detuvo realmente la API; E-01 forzó la acción desde el componente y obtuvo un 403 real. El cambio de roles de M-03 se ejecutó por la API administrativa y se restauró al terminar.

Los casos B usaron un JWT real de tres minutos, sin alterar su vencimiento ni renovar el token: el aviso apareció al quedar dos minutos, avanzó, se ocultó y la sesión terminó por vencimiento. Después se restauró la configuración del backend a 60 minutos.

La matriz conserva las ocho columnas exigidas y enlaza capturas originales de ventana. Los JWT se ocultaron en la vista de DevTools antes de capturar; no se guardan completos en los archivos de esta entrega. Las imágenes del PDF recortan espacios vacíos y conservan la dirección real del navegador.

C2. Hallazgos y correcciones

L-03. Envío doble de login - severidad media

Descripción: un doble clic produjo dos POST, frente a una petición esperada. **Evidencia:** L-03_inicial.png y hallazgo-L03.json; la repetición final está en L-03.png.

Causa: src/app/features/auth/pages/login/login.ts, ingresar(): el binding disabled podía actualizarse después del segundo evento y el método no comprobaba enviando. **Corrección propuesta y aplicada:** if (this.enviando()) return; al entrar. La repetición verificó un solo POST; commit 4732b42.

I-02. Mensaje de conexión mediante proxy - severidad baja

Descripción: al detener la API, el proxy devolvió 502 y la SPA mostró “No se pudo completar la operación”, en vez de explicar el fallo de conexión. **Evidencia:** I-02_inicial.png y hallazgo-I02.json; I-02.png corresponde a la repetición corregida.

Causa: src/app/core/utils/http-error.ts, mensajeError(): solo reconocía status 0 como conexión fallida. **Corrección propuesta y aplicada:** tratar 502, 503 y 504 como indisponibilidad del backend. La repetición muestra el mensaje de conexión y mantiene la sesión; commit d540d13.

M-03. Nombre completo del perfil - severidad baja

Descripción: faltaba el nombre en la tarjeta aunque el encabezado lo mostraba desde la sesión. **Evidencia:** M-03_nombre_inicial.png y hallazgo-M03.json. **Causa:** AuthService.obtenerPerfil esperaba nombreCompleto, pero UsuarioResponseDTO devuelve empleadoNombre. **Corrección propuesta y aplicada:** adaptar ese campo en el servicio; se verificó el nombre con los cuatro roles, sin modificar el backend. Commit 52ee242.

S-04: independencia entre pestañas

Cerrar sesión en una pestaña no cierra la segunda: sessionStorage se separa por pestaña. La segunda conservó su sesión y consultó /auth/me. El caso pide observar y explicar este comportamiento, por lo que pasa. En un equipo compartido puede quedar otra pestaña activa; una mejora sería BroadcastChannel para comunicar el cierre sin compartir el JWT.

Versionamiento

La rama parte de la práctica y tiene un PR hacia develop. Los cambios propios se hicieron el 25/10/2026: **quedan pendientes los commits en días distintos**. Se conservan las fechas reales.

C3. Análisis de seguridad

1. Validación de permisos en el backend

El menú, SiPermiso y permisoGuard son controles del navegador y el usuario puede modificar o invocar su JavaScript. En E-01 se llamó a ProductoList.darDeBaja desde la consola pese al botón oculto; el DELETE real recibió 403 y el producto no cambió. Por ello SecurityConfig debe validar CATALOGO_ESCRIBIR en el servidor en cada operación. La interfaz ayuda a navegar, mientras la API decide si una acción se autoriza.

2. Almacenamiento del token para la botica

AuthService usa sessionStorage: conserva el F5 y limita la persistencia a la pestaña o sesión del navegador, útil en equipos compartidos. localStorage persistiría después de cerrarlo y podría dejar la cuenta accesible al siguiente trabajador. Ambos son accesibles a JavaScript y un XSS puede extraer el token. Una cookie HttpOnly impide que JavaScript lea su valor, pero el navegador la envía automáticamente y exige revisar SameSite, Secure y CSRF. Para esta versión elegiría sessionStorage, como la arquitectura del curso, con expiración breve y cierre explícito; en una evolución coordinada con el backend evaluaría cookies HttpOnly.

3. Diferencia entre un rechazo de sesión y de permiso

errorInterceptor cierra sesión ante 401, salvo en /auth/login: indica que la credencial falta, venció o no es válida, como I-03. Ante 403 la identidad sigue siendo válida y solo se deniega la acción, como E-01; el componente muestra mensajeError y conserva la sesión. Invertirlo mantendría una credencial inválida con peticiones que fallan y expulsaría a trabajadores autenticados por una acción prohibida. Un fallo de conexión como I-02 tampoco equivale a 401.

4. Redirección abierta y returnUrl

Una redirección abierta permite que un parámetro controlado por un tercero mande al usuario a otro sitio después del login, lo que facilita engaños. Login.destino exige que returnUrl empiece con / y no con //, y usa /inicio en otro caso; navega con Router.navigateByUrl. En L-04 se introdujo https://sitio-falso.com y la SPA terminó en localhost:4200/inicio. La ruta recordada por authGuard sigue funcionando para direcciones internas, sin aceptar ese destino externo.

L-01 · Login · PASA

Usuario: Sin sesión
Pasos: Enviar vacío y después solo username.

Esperado: Validación sin POST.
Obtenido: Ambos campos obligatorios; con username solo falta contraseña. No se envió POST.



Captura original: L-01.png

L-02 · Login · PASA

Usuario: noexiste, admin, inactivo
Pasos: Enviar tres credenciales rechazadas.

Esperado: Mismo mensaje; borra clave y conserva username.
Obtenido: Tres HTTP 401 con idéntico mensaje genérico y campos según lo esperado.



Captura original: L-02.png

L-03 · Login · PASA

Usuario: vendedor
Pasos: Doble clic rápido en Ingresar con datos válidos.

Esperado: Un POST; botón bloqueado mientras envía.
Obtenido: Se observó 1 POST y se inició sesión.



Hallazgo inicial: dos peticiones; corregido y repetido con una. Captura inicial original: L-03_inicial.png.

Captura original: L-03.png

L-04 · Login · PASA

Usuario: vendedor
Pasos: Abrir login con returnUrl externo e ingresar.

Esperado: Navega a /inicio.
Obtenido: Se mantiene localhost:4200 y abre /inicio.



Captura original: L-04.png

L-05 · Login · PASA

Usuario: Sin sesión
Pasos: Activar y desactivar Mostrar contraseña.

Esperado: Alterna tipo sin cambiar el valor.
Obtenido: Tipos text/password y valor conservado, comprobados tras la actualización de la vista.



Captura original: L-05.png

S-01 · Sesión · PASA

Usuario: vendedor
Pasos: Login, F5, cerrar todo el navegador y abrirlo.

Esperado: F5 conserva sesión; navegador nuevo exige login.
Obtenido: F5 conservó vendedor; el navegador nuevo muestra login.



Captura original: S-01.png

S-02 · Sesión · PASA

Usuario: vendedor
Pasos: Poner expiraEn en el pasado y F5.

Esperado: Descarta la sesión guardada.
Obtenido: Login y clave de sesión eliminada.



Captura original: S-02.png

S-03 · Sesión · PASA

Usuario: vendedor
Pasos: Guardar texto no JSON en la sesión y F5.

Esperado: Login sin romper la SPA.
Obtenido: Login correcto; no hubo excepción de JavaScript sin manejar.

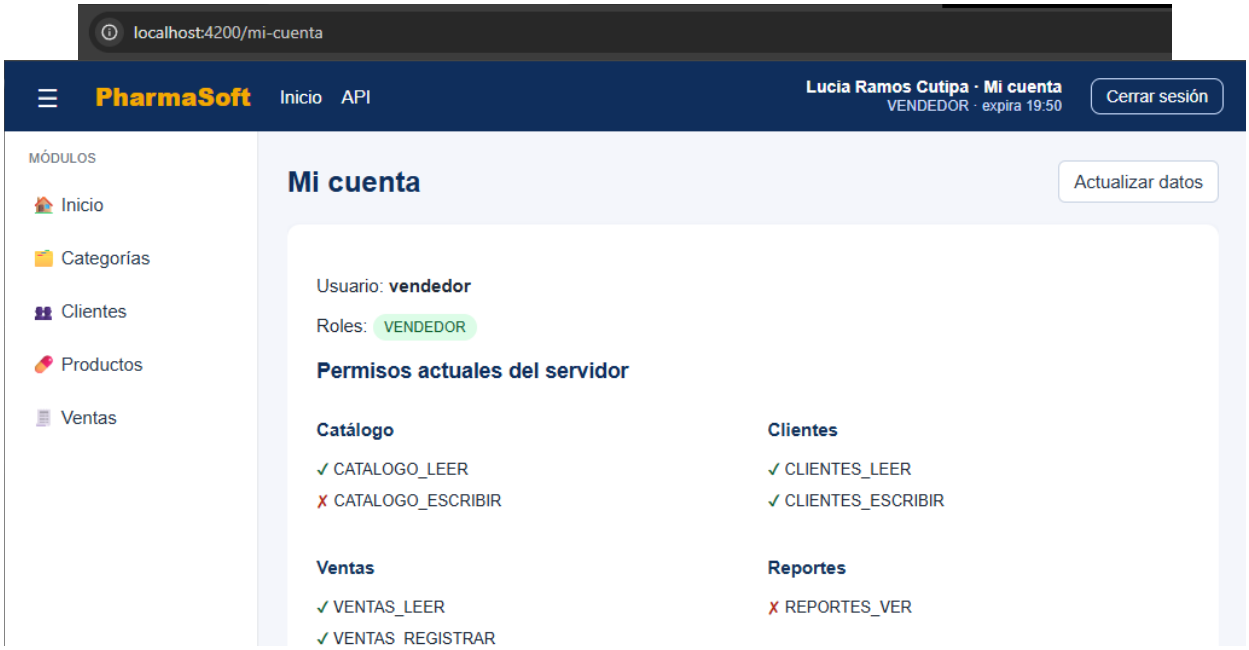


Captura original: S-03.png

S-04 · Sesión · PASA

Usuario: vendedor en dos pestañas
Pasos: Autenticar dos pestañas; salir en una y navegar en la otra.

Esperado: Registrar independencia por pestaña.
Obtenido: La segunda conserva su sesión y GET /auth/me responde 200; la primera queda en login.



Captura original: S-04.png

S-05 · Sesión · PASA

Usuario: vendedor
Pasos: Reducir el vencimiento local para activar el aviso; pulsar Cerrar sesión ahora y revisar el servicio.

Esperado: Intervalo limpio y contador cero.
Obtenido: Cerrar sesión ahora elimina sesión; intervalo undefined y segundosRestantes=0 verificados después de 1,3 s. No se alargó el JWT.

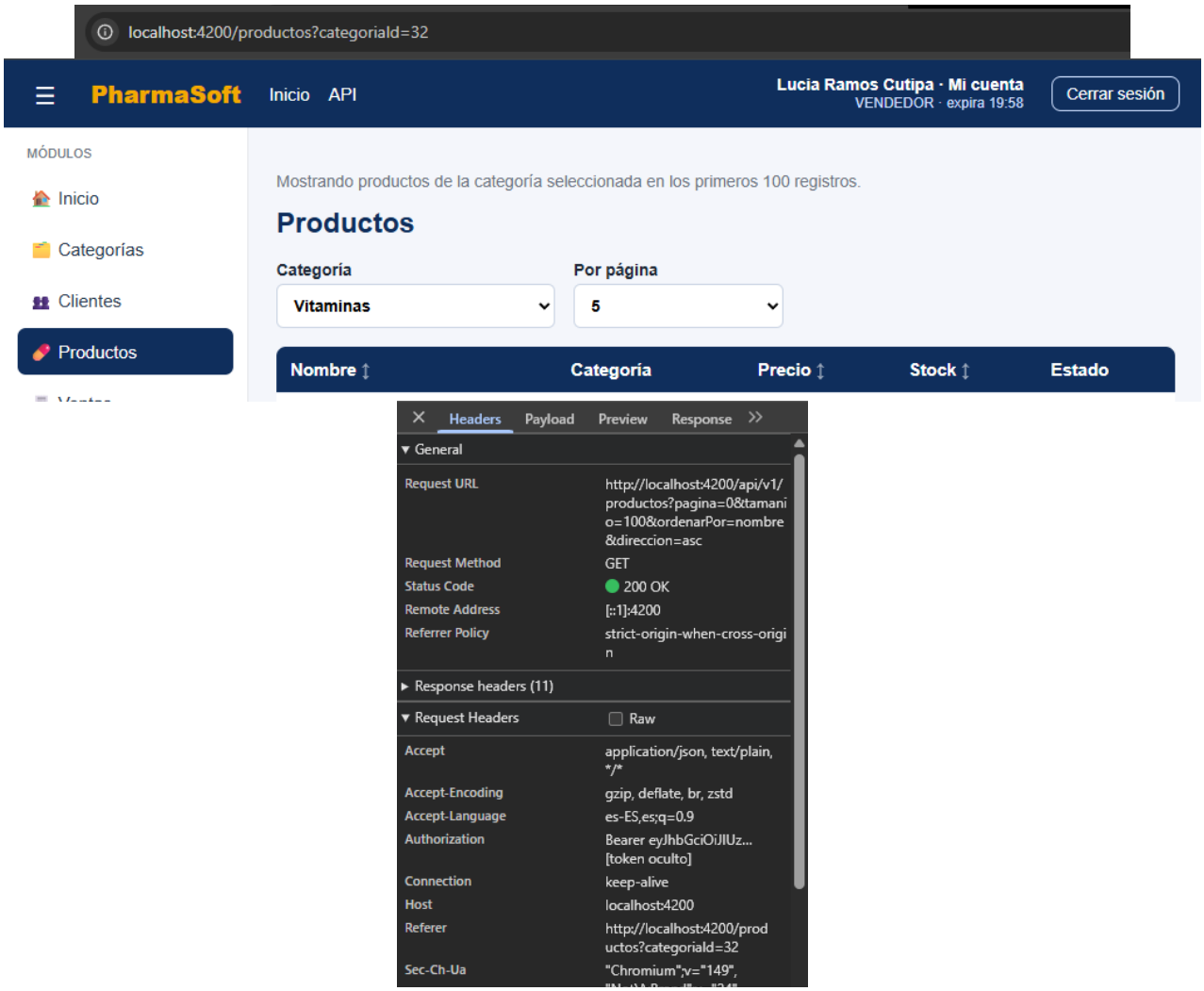


Captura original: S-05.png

I-01 · Interceptor · PASA

Usuario: vendedor
Pasos: Revisar login, GET productos y recurso de 127.0.0.1 en otro puerto/origen.

Esperado: Bearer solo a la API.
Obtenido: Productos lleva Bearer; login y servidor del recurso de otro origen no reciben Authorization. Imagen HTTP 200.

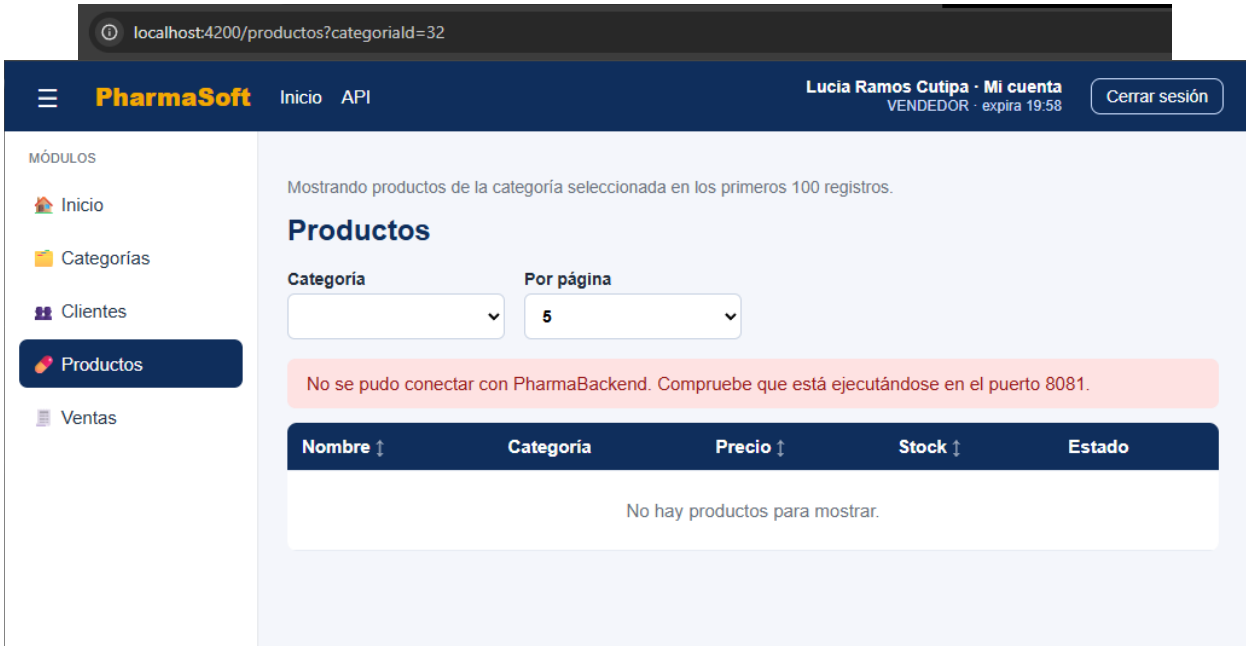


Captura original: I-01.png

I-02 · Interceptor · PASA

Usuario: vendedor
Pasos: Detener API y abrir Productos.

Esperado: Error de conexión sin cerrar sesión.
Obtenido: Mensaje de conexión; continúa vendedor autenticado, sin redirección.

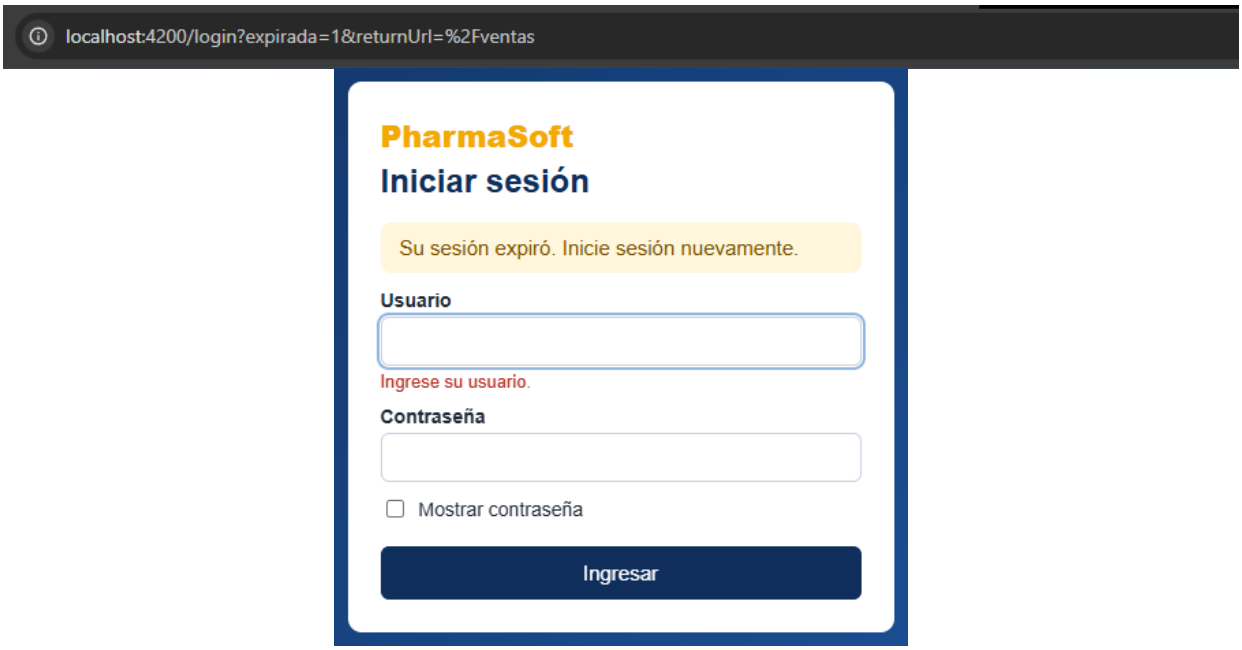


Captura original: I-02.png

I-03 · Interceptor · PASA

Usuario: vendedor
Pasos: Alterar JWT guardado y abrir Ventas recargando.

Esperado: 401, login con aviso y returnUrl=/ventas.
Obtenido: API 401; login con Su sesión expiró y retorno a Ventas.



Captura original: I-03.png

G-01 · Guards · PASA

Usuario: Sin sesión
Pasos: Abrir tres URL privadas sin sesión.

Esperado: Login recuerda cada URL.
Obtenido: returnUrl correcto en /productos/1/editar, /ventas/nueva, /inicio

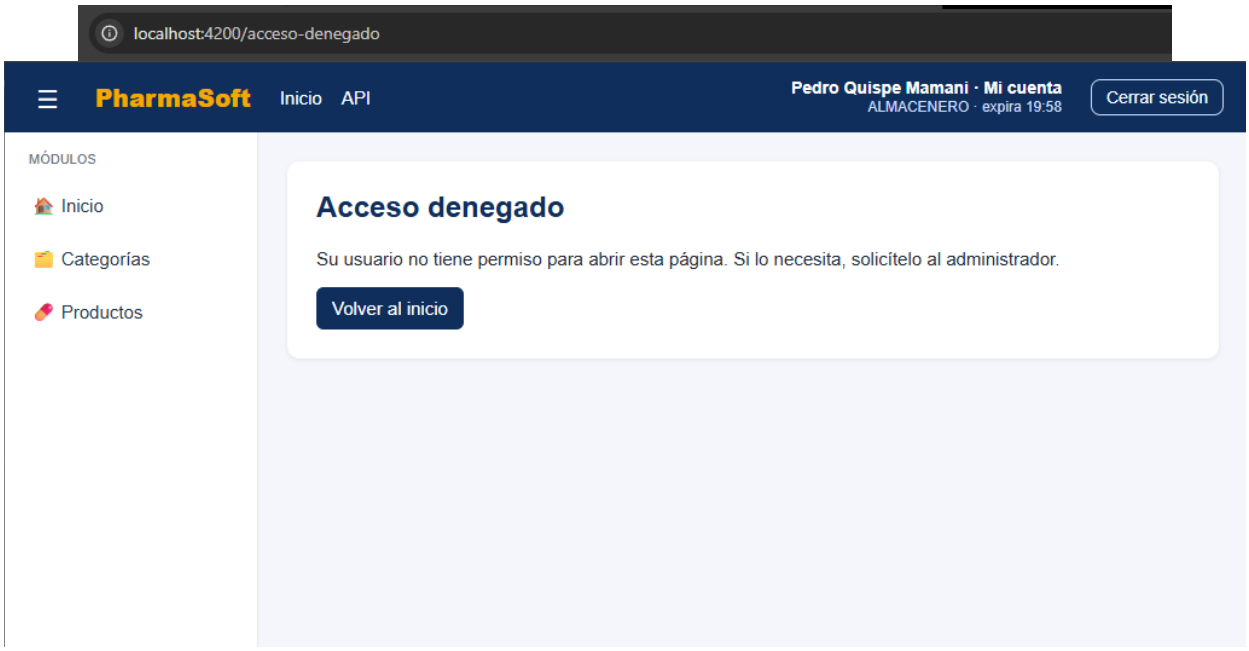


Captura original: G-01.png

G-02 · Guards · PASA

Usuario: vendedor y almacen
Pasos: Abrir las tres rutas de escritura sin permiso.

Esperado: Acceso denegado sin código numérico visual.
Obtenido: Las tres rutas terminan en Acceso denegado; conservan sesión.

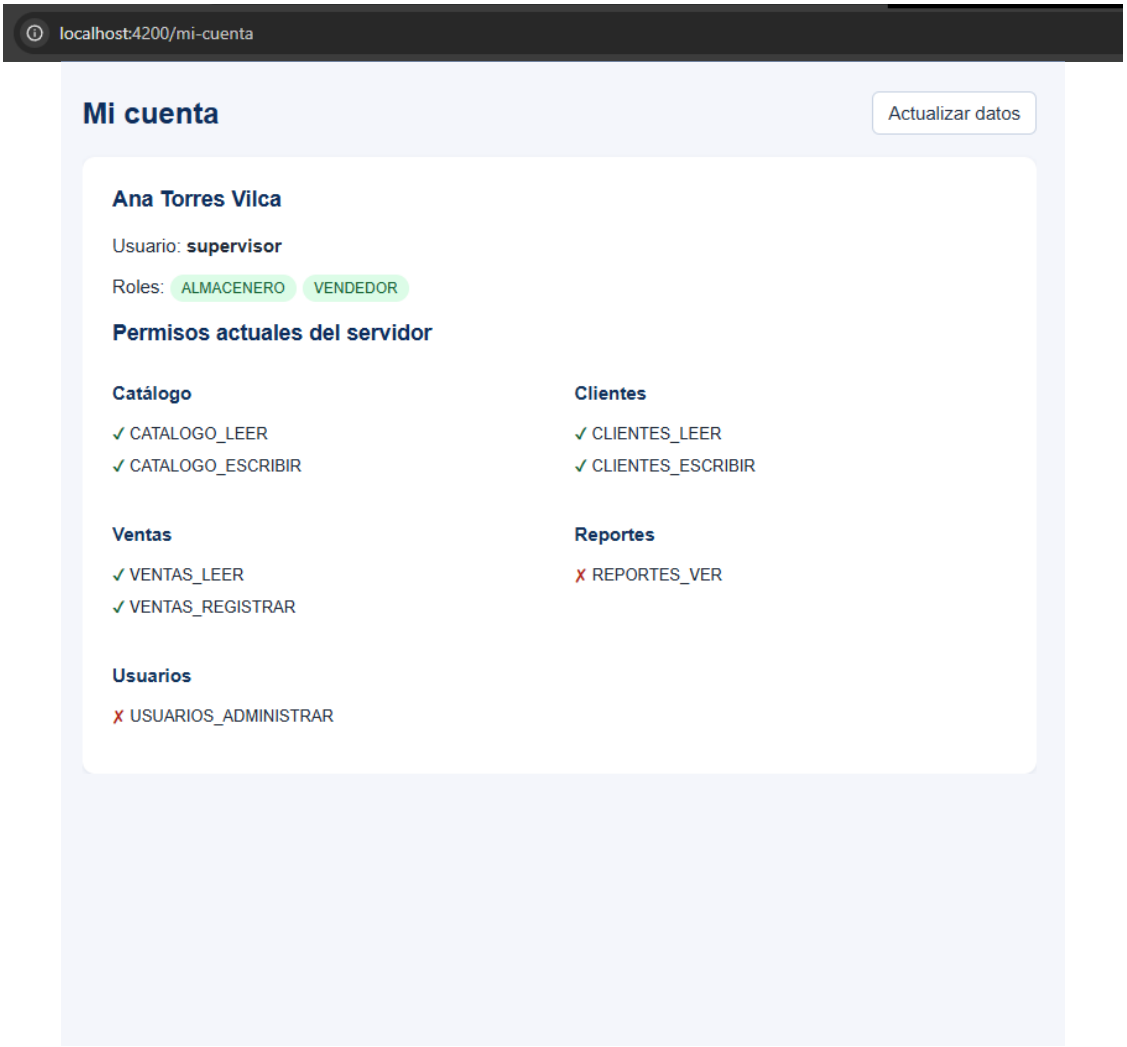


Captura original: G-02.png

G-03 · Guards · PASA

Usuario: cuatro usuarios activos
Pasos: Abrir Mi cuenta con cada rol, verificar nombre y cinco módulos, después sin sesión.

Esperado: Todo autenticado accede sin permiso adicional; anónimo no.
Obtenido: GET /auth/me 200 en los cuatro roles; nombre completo y cinco módulos visibles. Sin sesión exige login con returnUrl=/mi-cuenta.



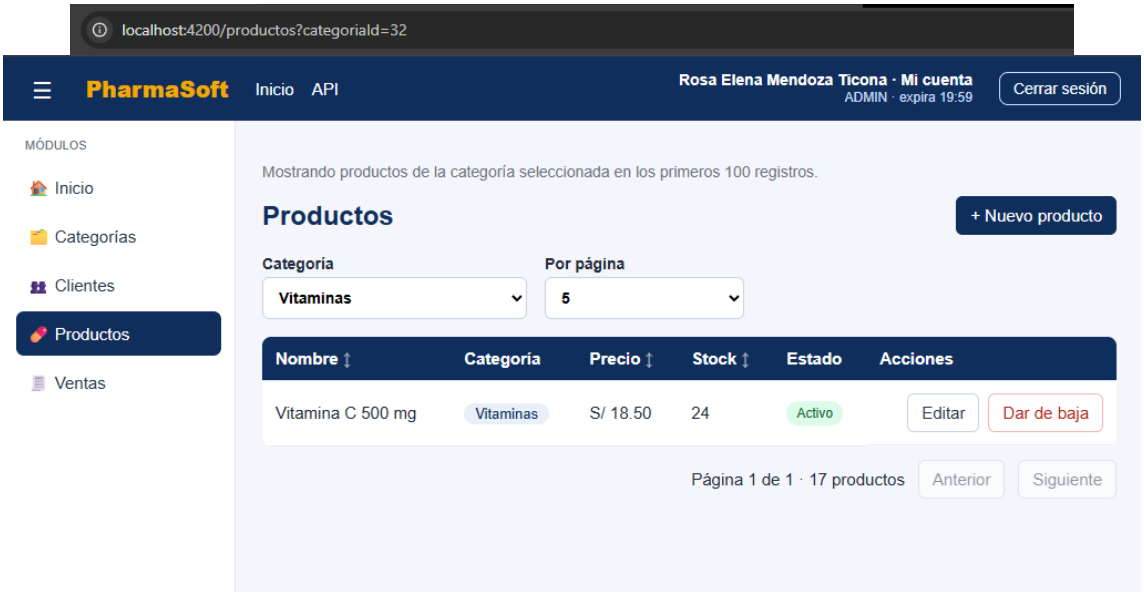
Captura original: G-03.png

M-01 · Menú y acciones · PASA · comparación 1/2

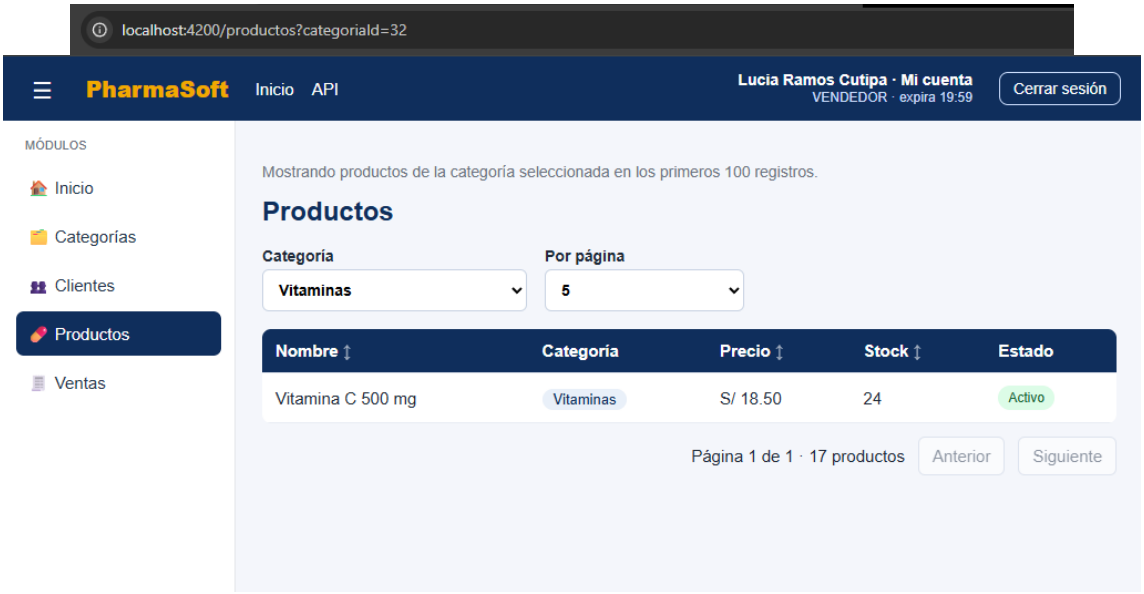
Usuario: cuatro usuarios activos
Pasos: Comparar menú y acciones de Productos con los cuatro roles.

Esperado: Permisos exactos; supervisor une roles.
Obtenido: Admin/supervisor ven ventas y edición; vendedor ve ventas sin edición; almacén edita sin ventas.

admin



vendedor



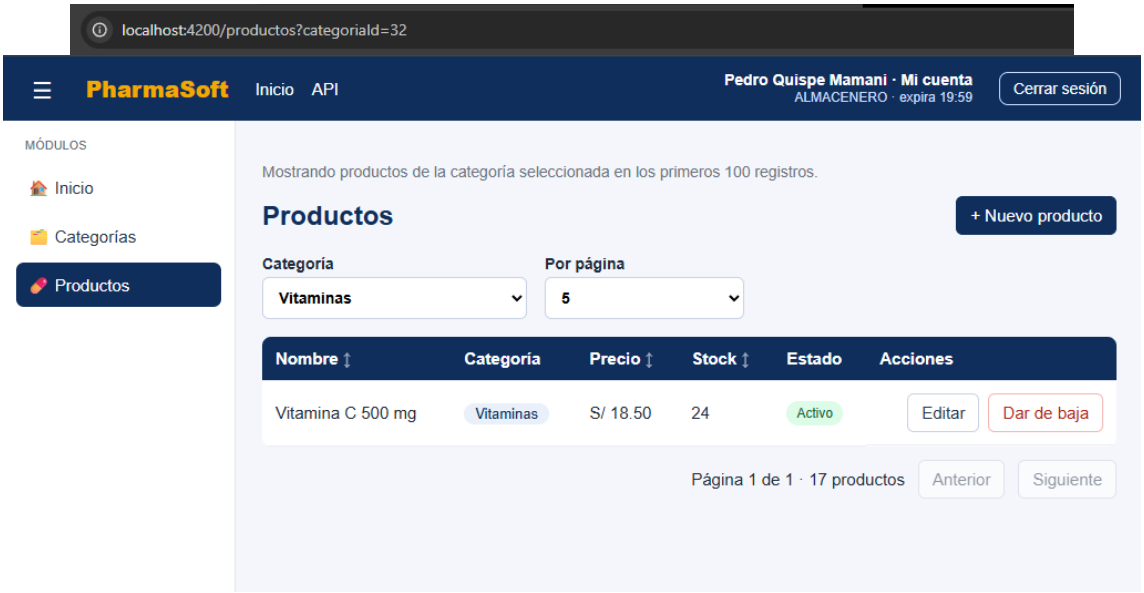
Captura original: M-01_admin.png, M-01_vendedor.png

M-01 · Menú y acciones · PASA · comparación 2/2

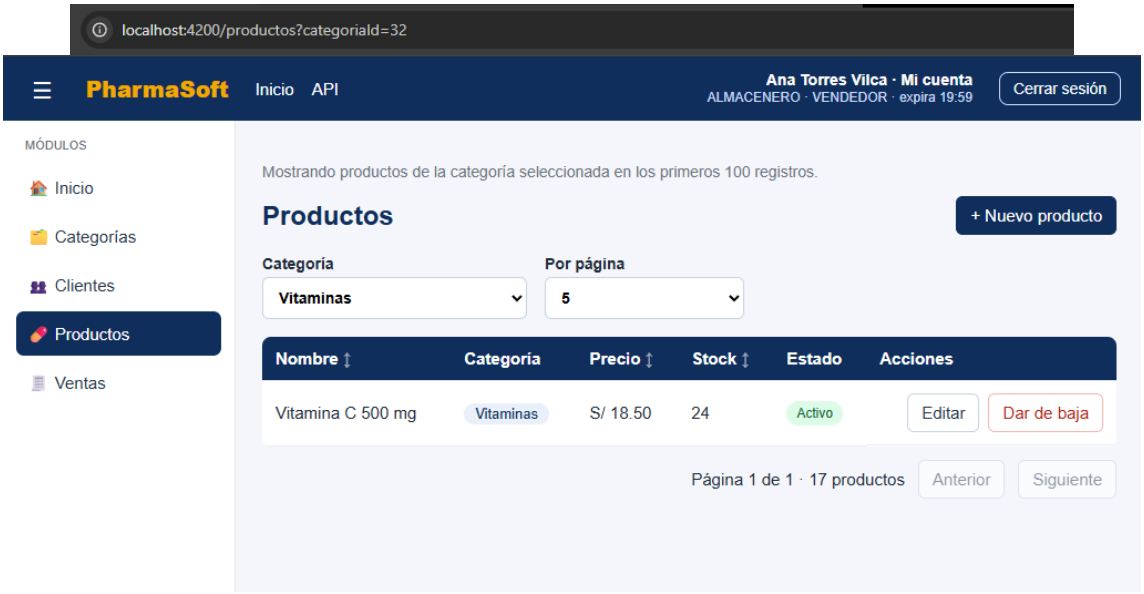
Usuario: cuatro usuarios activos
Pasos: Comparar menú y acciones de Productos con los cuatro roles.

Esperado: Permisos exactos; supervisor une roles.
Obtenido: Admin/supervisor ven ventas y edición; vendedor ve ventas sin edición; almacén edita sin ventas.

almacen



supervisor



Captura original: M-01_almacen.png, M-01_supervisor.png

M-02 · Menú y acciones · PASA

Usuario: admin → almacen
Pasos: Cambiar de usuario mediante logout/login sin F5.

Esperado: computed actualiza menú.
Obtenido: Desaparece Ventas y el encabezado muestra ALMACENERO sin recarga.

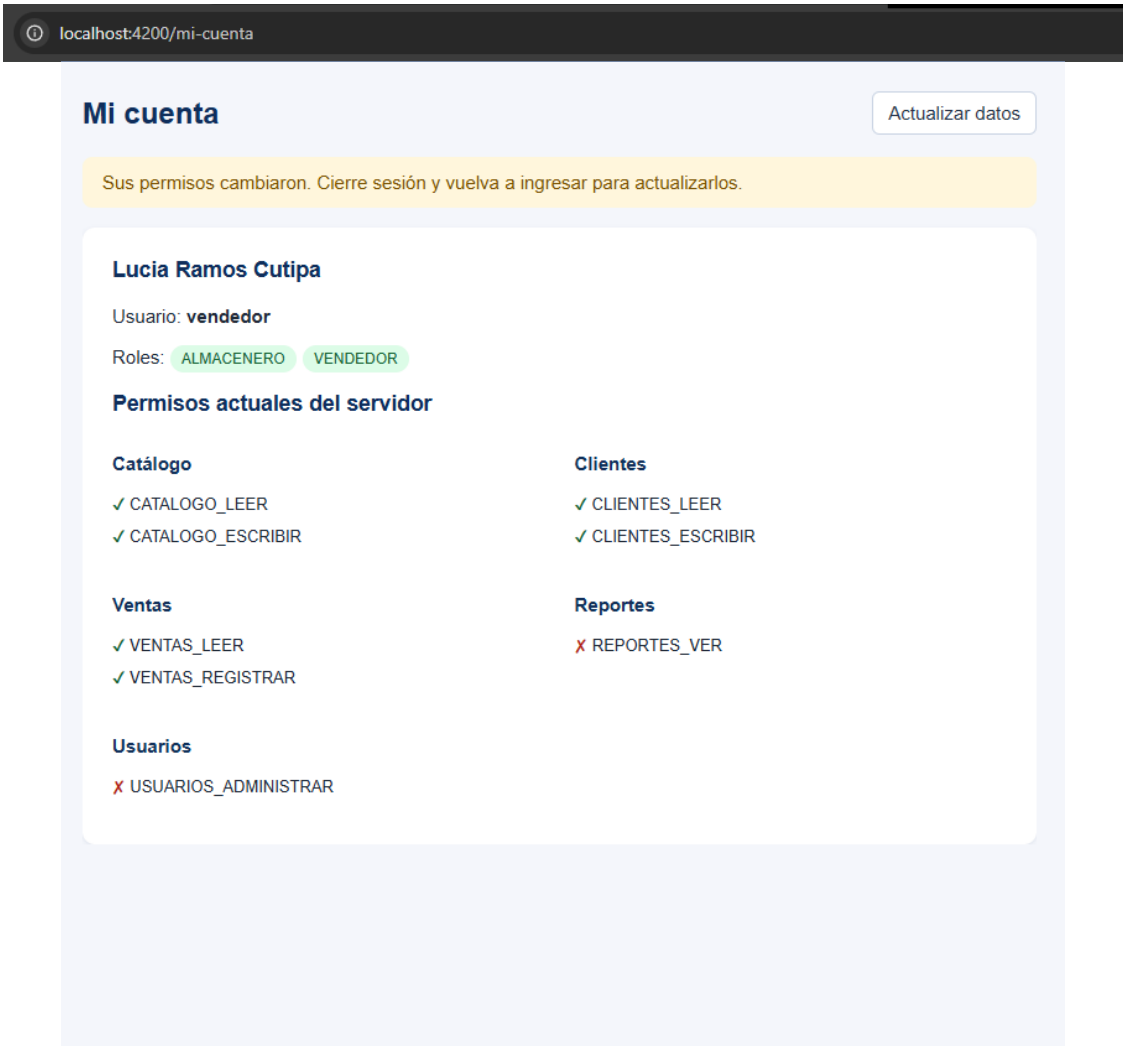


Captura original: M-02.png

M-03 · Menú y acciones · PASA

Usuario: vendedor; admin cambia y restaura roles
Pasos: Ver carga, perfil, cambio real de permisos y error sin backend.

Esperado: Carga/error y comparación servidor/sesión.
Obtenido: Estados correctos, cinco módulos con □/□ y aviso de permisos distintos. Roles originales restaurados.

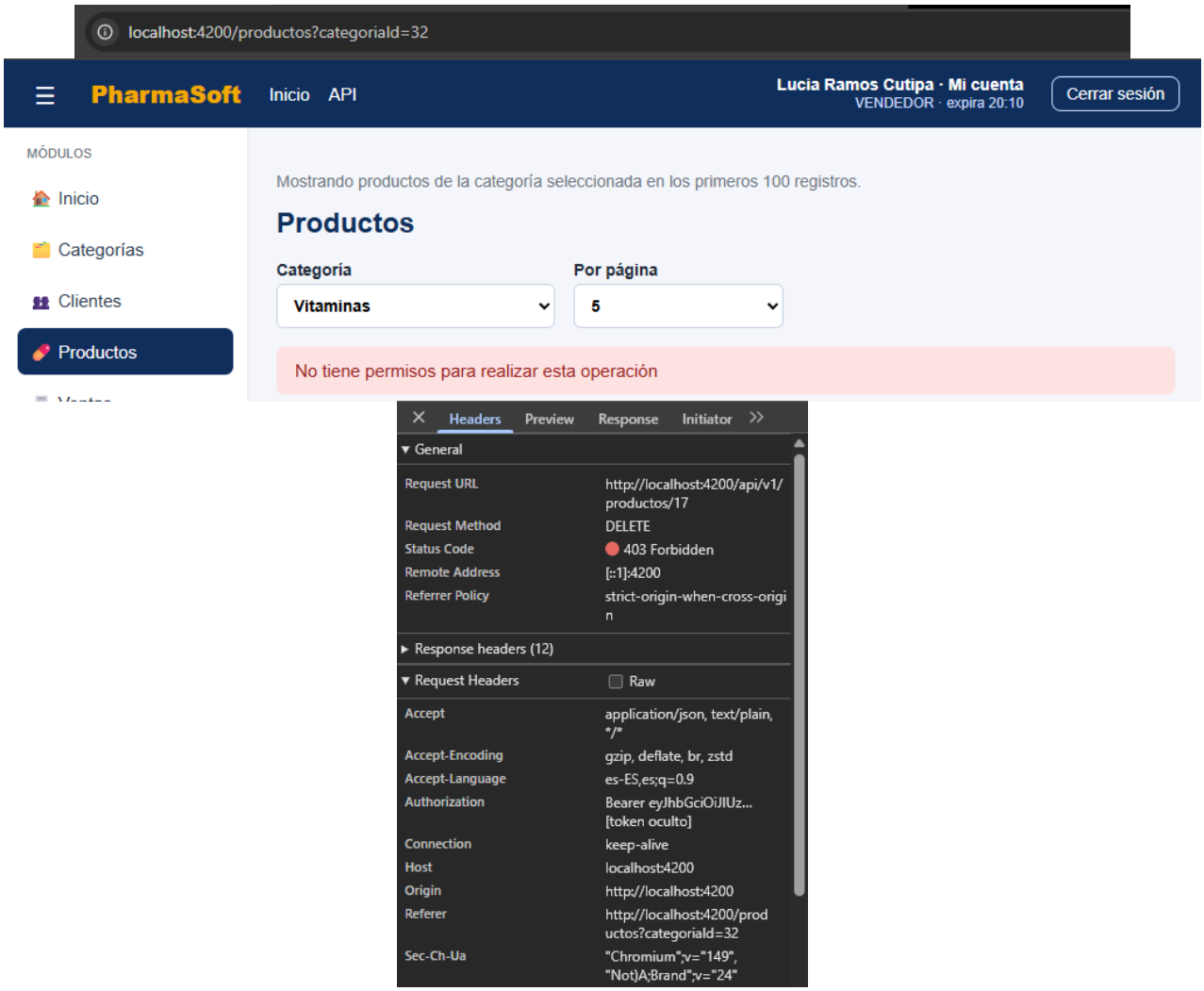


Captura original: M-03_permisos.png

E-01 · 401 / 403 · PASA

Usuario: vendedor
Pasos: Forzar darDeBaja desde la consola del componente.

Esperado: 403 del servidor; mensaje y sesión vigente.
Obtenido: DELETE responde 403; mensaje sin número visible y continúa vendedor. El producto no se modificó.



Captura original: E-01.png

B-01 · Aviso de expiración · PASA

Usuario: vendedor
Pasos: Emitir token real de tres minutos y esperar hasta que queden dos.

Esperado: Aviso al quedar ≤120 s.
Obtenido: Aviso 02:00 tras 58 s; no apareció al iniciar.

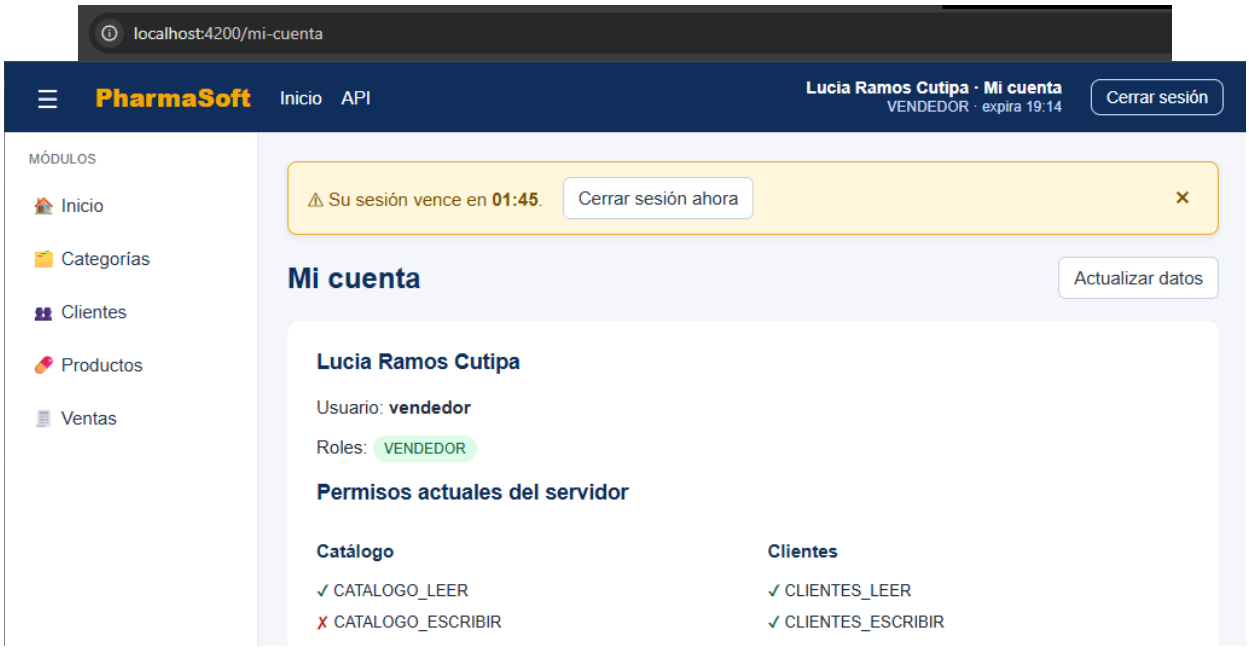


Captura original: B-01.png

B-02 · Aviso de expiración · PASA

Usuario: vendedor
Pasos: Observar el contador varios segundos.

Esperado: mm:ss disminuye cada segundo.
Obtenido: Avanzó de 02:00 a 01:51 sin cambiar expiraEn ni renovar JWT.



Captura original: B-02.png

B-03 · Aviso de expiración · PASA

Usuario: vendedor
Pasos: Pulsar × y recargar durante la misma sesión.

Esperado: Oculta aviso hasta la siguiente sesión, sin cerrarla.
Obtenido: Aviso oculto también tras F5; Mi cuenta y la sesión siguen activos.



Captura original: B-03.png

B-04 · Aviso de expiración · PASA

Usuario: vendedor
Pasos: Esperar el vencimiento real del JWT de tres minutos.

Esperado: Login al llegar a cero, sesión y temporizadores limpios.
Obtenido: Expiración real tras 179 s; elimina sesión y avisa con returnUrl=/mi-cuenta.

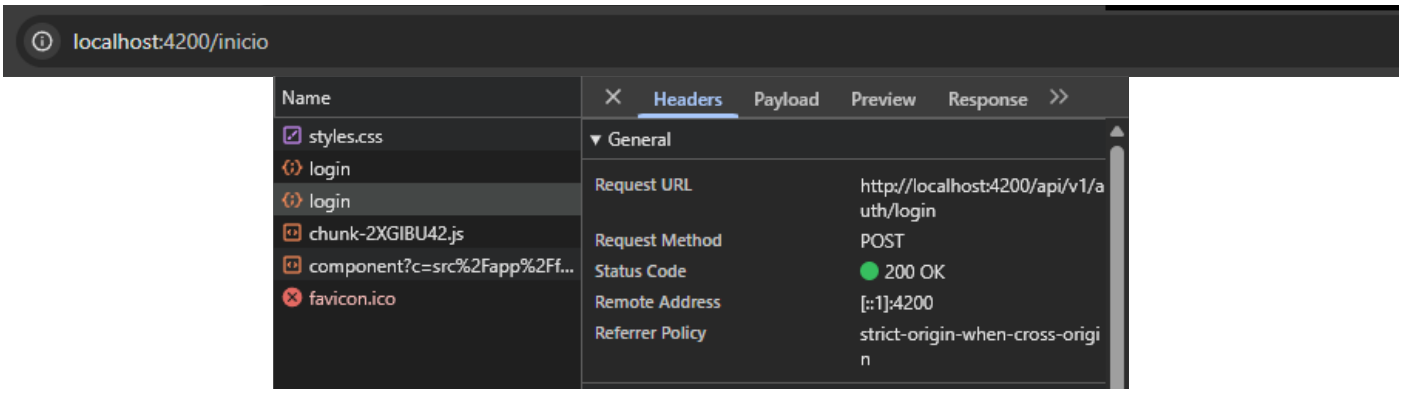


Captura original: B-04.png

L-03 (inicial) · Hallazgo corregido · FALLÓ; CORREGIDO

Usuario: vendedor
Pasos: Antes de corregir el código.

Esperado: Un POST de login.
Obtenido: Dos POST; corregido y repetido con uno.

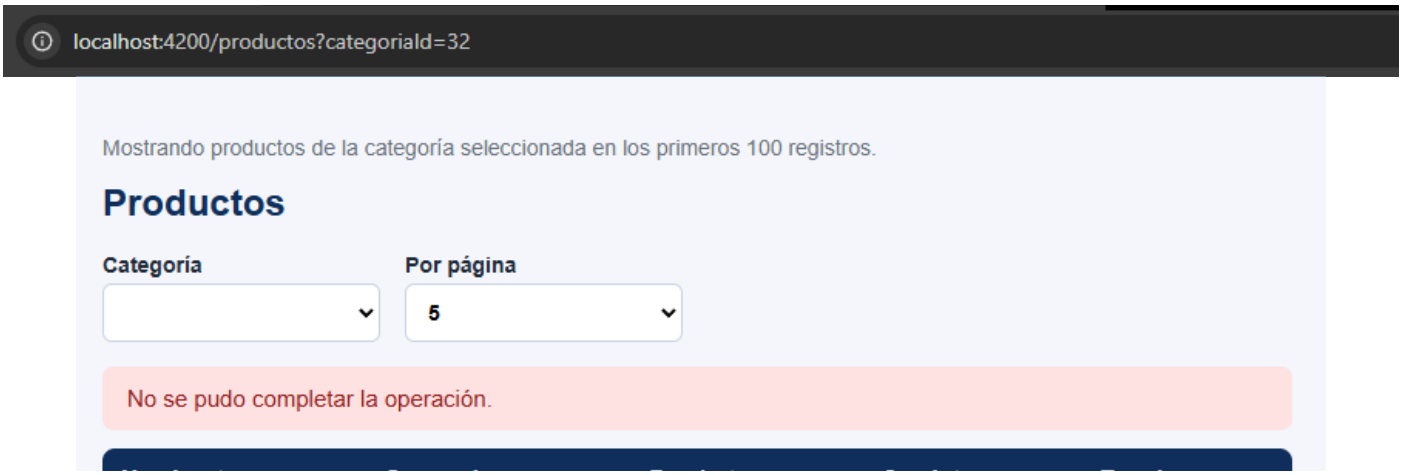


Captura original: L-03_inicial.png

I-02 (inicial) · Hallazgo corregido · FALLÓ; CORREGIDO

Usuario: vendedor
Pasos: Antes de corregir el código.

Esperado: Mensaje de conexión.
Obtenido: Mensaje genérico; corregido para el proxy.

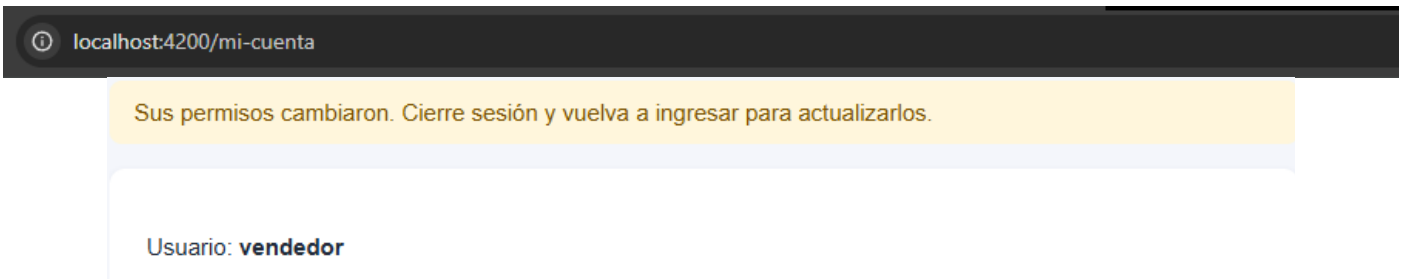


Captura original: I-02_inicial.png

M-03 (inicial) · Hallazgo corregido · FALLÓ; CORREGIDO

Usuario: vendedor
Pasos: Antes de corregir el código.

Esperado: Nombre completo en la tarjeta.
Obtenido: Faltaba el nombre; la versión final lo muestra.



Captura original: M-03_nombre_inicial.png